

Incident Response & Security Reporting Policy

IT-05 | Version 1.0 | Effective 01 September 2026

Owner: IT & Security | Applies to employees and contractors

Fictional company policy for RAG training and evaluation. All .example addresses are placeholders; these are not live services.

1. Purpose and scope

Help staff report and contain suspected security incidents quickly. Report phishing, unexpected MFA prompts, malware alerts, lost devices, exposed credentials and possible data disclosure. You do not need proof before reporting. Prompt good-faith reporting is encouraged; do not investigate by accessing someone else's account.

2. Reporting deadlines and channels

Report suspected incidents immediately, and no later than 1 hour after discovery. Use security@northstar.example or the Security Incident form at <https://support.northstar.example>. If company sign-in or email is unavailable, use <https://security.northstar.example/report> from another device; this form does not require sign-in. The security reporting queue is monitored 24/7. Routine IT requests are handled Monday-Friday, 09:00-17:00 UTC, excluding company holidays.

3. Information to include

Provide your name, a reachable contact, discovery time with time zone, affected account or device asset tag, what happened and what you already did. Include the sender, subject and received time for suspected phishing. Attach safe screenshots if useful. Never submit passwords, recovery codes or MFA codes. Use the reporting form rather than replying to a suspicious message.

4. Immediate employee actions

For phishing, do not click links, open attachments or forward the message to coworkers. Use the email Report Phishing button or the channels above. For an unexpected MFA prompt, reject it and report it immediately. If malware or ransomware is suspected, disconnect Wi-Fi and the network cable, stop using the device and report from a different device. Keep the device powered on unless Security tells you otherwise.

Incident Response & Security Reporting Policy

Procedures and responsibilities

5. Credential and device incidents

If credentials may be exposed, contact Security immediately and reset the password through the known identity portal under IT-01 if safe to do so. Security revokes sessions and compromised factors as needed. Report a lost or stolen device within the same 1-hour limit, with the last known location and whether it was unlocked. Security coordinates remote lock or wipe under IT-02.

6. Triage and response targets

Security assigns severity. P1 covers active ransomware, confirmed account takeover or ongoing sensitive-data exposure: target acknowledgment within 15 minutes of receipt. P2 covers suspected compromise without evidence of active spread: target acknowledgment within 1 hour. P3 covers blocked phishing with no interaction: target acknowledgment within 4 hours. These are 24/7 acknowledgment targets, not resolution guarantees. If the target passes without acknowledgment, resubmit through the alternate reporting channel and reference the original report time.

7. Containment and evidence

The Security incident lead may isolate devices, revoke sessions, block accounts and request emergency access under IT-04. Preserve original messages, screenshots and logs. Do not delete files, reinstall software, factory-reset the device or perform a forensic investigation yourself. Security records evidence access and coordinates with Legal before external notifications. Employees must not contact affected customers or publish incident details unless explicitly assigned to do so.

8. Closure and follow-up

Security confirms containment and recovery before IT restores normal access. For P1 and P2 incidents, the incident lead completes a review within 5 business days after closure, recording cause, impact and preventive actions with owners. See IT-01 through IT-04 for credential recovery, device handling, VPN restrictions and access approval.